MAINCRAFTS INTERNSHIP PROGRAM

Cybersecurity Threat Report

Five Major Modern Cyber Threats: Impact, Case Studies and Prevention

Task-1 | Awareness & Research Project

Submitted by: Harish

Domain: Cyber Security

Date: October 2026

Table of Contents

1. Introduction to Cybersecurity **3**

1.1 What is Cybersecurity? 3

1.2 Why is it Important? 3

1.3 Current Relevance 3

2. Threat Analysis: Five Major Modern Cyber Threats **4**

Threat 1: AI-Powered Phishing Attacks **5**

Threat 2: Ransomware-as-a-Service (RaaS) **6**

Threat 3: Cloud Security Misconfigurations **7**

Threat 4: IoT Vulnerabilities **8**

Threat 5: Zero-Day Exploits **9**

3. Summary: Threats and Defences **10**

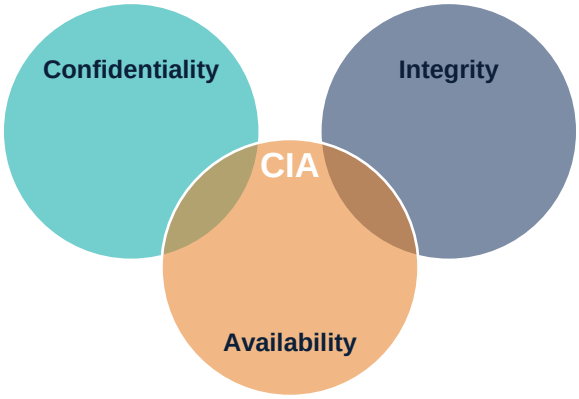
4. Conclusion & Future Scope **10**

5. References **11**

1. Introduction to Cybersecurity

1.1 What is Cybersecurity?

Cybersecurity is the practice of protecting computers, networks, apps and data from attacks, theft and damage. It keeps digital systems safe, private and working. Its goals are summed up by the **CIA Triad**:



- **Confidentiality:** only authorised people can see the data.
- **Integrity:** data stays correct and is not secretly changed.
- **Availability:** systems and data are ready when users need them.

1.2 Why is it Important?

For Individuals	For Businesses
• Protects bank accounts, UPI/cards and identity • Keeps photos, chats and personal data private • Prevents scams, blackmail and identity theft	• Protects customer data and trade secrets • Avoids downtime and loss of money • Keeps trust and meets laws (e.g. GDPR, India's DPDP Act 2023)

The IBM *Cost of a Data Breach Report 2024* found that the global average cost of one data breach was about **USD 4.88 million**. The Verizon *Data Breach Investigations Report 2024* found that the human element (mistakes, stolen passwords, social engineering) was involved in about two-thirds of breaches.

1.3 Current Relevance

- **Cyber crime is rising:** attacks are cheaper, easier and more profitable for criminals.
- **Digital dependency:** banking, health, education, shopping and government now run online and on the cloud.
- **AI-driven threats:** attackers use AI to write perfect phishing mails, clone voices and faces, and find weaknesses faster. Defenders use AI too, so it is a race.
- **More devices:** billions of smart devices (IoT) are online, and many are poorly secured.

Overview of this report

This report studies five major modern cyber threats: AI-powered phishing, Ransomware-as-a-Service, cloud misconfigurations, IoT vulnerabilities and zero-day exploits. For each one, it explains the impact on individuals and organizations, a real-world case study, and practical prevention steps. It ends with a defence summary and future scope.

2. Threat Analysis: Five Major Modern Cyber Threats

This report studies five threats that are active today. The table gives a quick overview. The chart gives an *illustrative* rating (scale 1-10) made by the author from the research, not an official statistic.

#	Threat	One-line meaning	Case study
1	**AI-Powered Phishing**	Fake emails, voices and videos made with AI to trick people	Arup deepfake fraud (2024)
2	**Ransomware-as-a-Service**	Ready-made ransomware rented to criminals	Colonial Pipeline (2021)
3	**Cloud Misconfiguration**	Wrong cloud settings expose data	Capital One breach (2019)
4	**IoT Vulnerabilities**	Smart devices with weak security get hacked	Mirai botnet / Dyn (2016)
5	**Zero-Day Exploits**	Attacks on flaws that have no patch yet	MOVEit Transfer (2023)

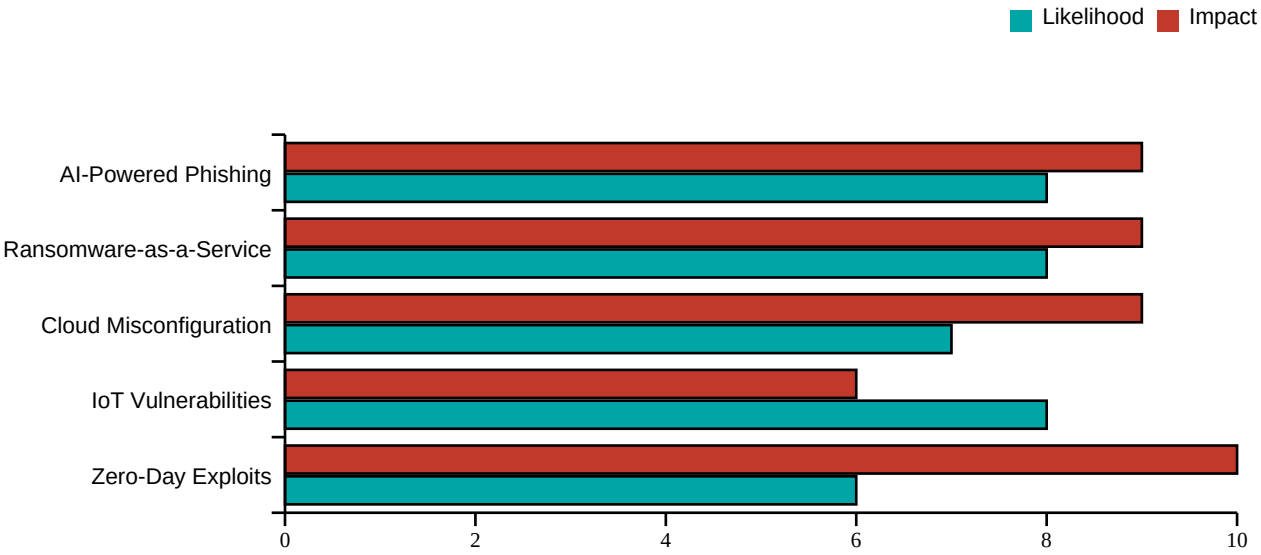


Figure 1: Illustrative likelihood and impact rating of the five threats (author's assessment).

1 AI-Powered Phishing Attacks

What is it?

Phishing tricks a person into giving passwords, money or data. With AI, attackers can write mails with no spelling mistakes, copy a person's writing style, clone a voice from a few seconds of audio, and create **deepfake** videos of managers or relatives. This makes social engineering much more believable and easy to do at large scale.

Impact analysis

Who is harmed	How
Individuals	Stolen passwords and bank/UPI details, financial fraud, identity theft, fake emergency calls using a cloned voice of a family member, and blackmail.
Organizations	Business Email Compromise (BEC) and fake CEO requests cause large money loss; stolen staff logins lead to data breaches; loss of customer trust; possible legal and compliance trouble.

Real-world case study: Arup Deepfake Video Call Fraud (2024)

In early 2024, an employee of the engineering firm **Arup** in Hong Kong joined a video call that looked like it had the company's CFO and other colleagues. They were all AI-made deepfakes. The employee was convinced and made **15 transfers worth about HK$200 million (around US$25 million)** to criminals.
Lesson: seeing a face and hearing a voice on a call is no longer proof of identity. Payments need a second, separate check.

Preventive measures

Control	How it helps
Multi-Factor Authentication (MFA)	Even if a password is stolen, the attacker still needs a second factor. Phishing-resistant MFA (passkeys, security keys) is best.
Security Awareness Training	Teach staff to spot urgency, odd requests and fake links. Run regular phishing simulations.
Out-of-band verification	Confirm money or data requests using a known phone number or in person, with a two-person approval for large payments.
Email filtering and DMARC/SPF/DKIM	Blocks spoofed senders and known bad links before they reach inboxes.

2 Ransomware-as-a-Service (RaaS)

What is it?

Ransomware locks or steals files and demands money to unlock them. In **RaaS**, expert developers build the malware and rent it to "affiliates" in return for a share of the ransom (often 20-30%). Anyone can launch an attack without deep technical skill, so attacks have grown fast. Many gangs also use **double extortion**: they steal data first and threaten to leak it.

Impact analysis

Who is harmed	How
Individuals	Personal files, photos and documents locked; ransom demands; leak of private data; services such as hospitals or schools stop working.
Organizations	Systems down for days or weeks, lost revenue, ransom and recovery costs, leaked customer data, reputation damage and fines for breaking data laws.

Real-world case study: Colonial Pipeline Attack (2021)

In May 2021, the **DarkSide** RaaS group attacked **Colonial Pipeline**, a major fuel pipeline in the USA. The company shut down the pipeline to stop the spread. This caused fuel shortages and panic buying on the US East Coast. The company paid about **75 Bitcoin (around US$4.4 million)**, and US authorities later recovered part of it. The attack reportedly began with a single compromised VPN password that had no MFA.
Lesson: one weak account can stop critical infrastructure.

Preventive measures

Control	How it helps
Offline, tested backups (3-2-1 rule)	3 copies, 2 media types, 1 offline. You can restore without paying.
Patch management and least privilege	Close known holes quickly and limit what each user can access, so malware cannot spread.
EDR/Antivirus and network segmentation	Detects ransomware behaviour early and keeps one infected PC from reaching all systems.
MFA on remote access	Stops stolen VPN or RDP passwords from being enough.

3 Cloud Security Misconfigurations

What is it?

Cloud providers (AWS, Google Cloud, Azure) secure the infrastructure, but customers must configure their own settings. This is the **Shared Responsibility Model**. Common mistakes: public storage buckets, weak access rules (IAM), open ports, default passwords, exposed keys and no logging. One wrong setting can expose millions of records.

Impact analysis

Who is harmed	How
Individuals	Personal data such as names, addresses, ID numbers and financial details leak, leading to fraud, identity theft and spam or phishing.
Organizations	Large data breaches, regulator fines, lawsuits, costly investigations, and a damaged brand.

Real-world case study: Capital One Breach (2019)

In 2019, an attacker exploited a **misconfigured web application firewall** at Capital One hosted on AWS. Using a server-side request forgery (SSRF) trick, the attacker obtained credentials and accessed storage data. About **100 million people in the USA and 6 million in Canada** were affected. The US regulator (OCC) later fined the bank **US$80 million** in 2020.
Lesson: a small configuration error plus over-powered permissions can cause a massive breach.

Preventive measures

Control	How it helps
Cloud Security Posture Management (CSPM)	Tools that scan cloud accounts and warn about risky settings automatically.
Least-privilege IAM and MFA	Give each user and service only the access it needs; protect admin accounts with MFA.
Encryption and logging	Encrypt data at rest and in transit; keep audit logs and alerts to catch strange activity early.

4 IoT Vulnerabilities

What is it?

IoT (Internet of Things) devices include smart cameras, routers, TVs, watches, smart bulbs and industrial sensors. Many ship with **default passwords**, old software, no update system and weak encryption. Attackers take them over to spy, to enter the home or office network, or to join them into large **botnets**.

Impact analysis

Who is harmed	How
Individuals	Spying through hacked cameras and baby monitors, privacy loss, home network takeover, and devices slowing down or being used in crimes without the owner knowing.
Organizations	Entry point into company networks, DDoS attacks, disruption of smart factories, hospitals and buildings, and safety risks.

Real-world case study: Mirai Botnet and Dyn DDoS (2016)

The **Mirai** malware scanned the internet for IoT devices (cameras, DVRs, routers) that used default usernames and passwords and took them over. In October 2016, this botnet launched a huge DDoS attack on DNS provider **Dyn**. Popular sites including **Twitter, Netflix, Reddit and Spotify** became unreachable for many users. Earlier, the same botnet hit the website of security journalist Brian Krebs.
Lesson: cheap devices with default passwords can harm the whole internet.

Preventive measures

Control	How it helps
Change default passwords + update firmware	The simplest and most effective fix; turn on auto-updates where possible.
Network segmentation	Put IoT devices on a separate Wi-Fi/VLAN so they cannot reach computers and servers.
Firewall and IDS/IPS	Block unwanted traffic and detect botnet-like behaviour from devices.
Buy secure devices	Choose vendors that give regular security updates.

5 Zero-Day Exploits

What is it?

A **zero-day** is a software flaw that the vendor does not know about, so there is *zero days* to fix it. Attackers use it before a patch exists, so normal antivirus often cannot stop it. They are used by criminal gangs and state-backed groups, often against popular software used by many organisations.

Impact analysis

Who is harmed	How
Individuals	Device or browser takeover, spyware, stolen data and accounts, even with no click needed in some attacks.
Organizations	Mass data theft, supply-chain damage, emergency patching work, legal duties to notify victims, and loss of trust.

Real-world case study: MOVEit Transfer Attack (2023)

In May 2023, the **Cl0p** ransomware gang exploited a zero-day SQL injection flaw in **MOVEit Transfer**, a file-transfer tool (CVE-2023-34362). Data was stolen from **well over 2,000 organisations**, including companies, universities and government bodies, affecting tens of millions of people. CISA and the FBI issued a joint advisory. Another famous example is **Log4Shell** (CVE-2021-44228, 2021), a flaw in the widely used Log4j library.

Lesson: one flaw in one popular product can affect thousands of victims at once.

Preventive measures

Control	How it helps
Patch management	Apply updates quickly once a fix is released; track all software in use (asset inventory).
Zero Trust Security Model	'Never trust, always verify': limit access and movement, so one hole does not open everything.
IDS/IPS, EDR and WAF	Detect strange behaviour even when the exact exploit is unknown.
Reduce exposure	Remove unused services, apply virtual patching and monitor threat alerts (CISA, vendor advisories).

3. Summary: Threats and Defences

Threat	Main target	Top defences
AI Phishing	People	MFA, awareness training, call-back verification
RaaS	Files and systems	Offline backups, patching, segmentation, EDR
Cloud Misconfiguration	Cloud data	CSPM, least privilege, encryption, logging
IoT Vulnerabilities	Smart devices	Change passwords, update, segment network
Zero-Day Exploits	Software flaws	Fast patching, Zero Trust, IDS/IPS

Key idea: defence in depth. No single tool is enough. Using many layers (people, process and technology) means that if one layer fails, another still protects the system.

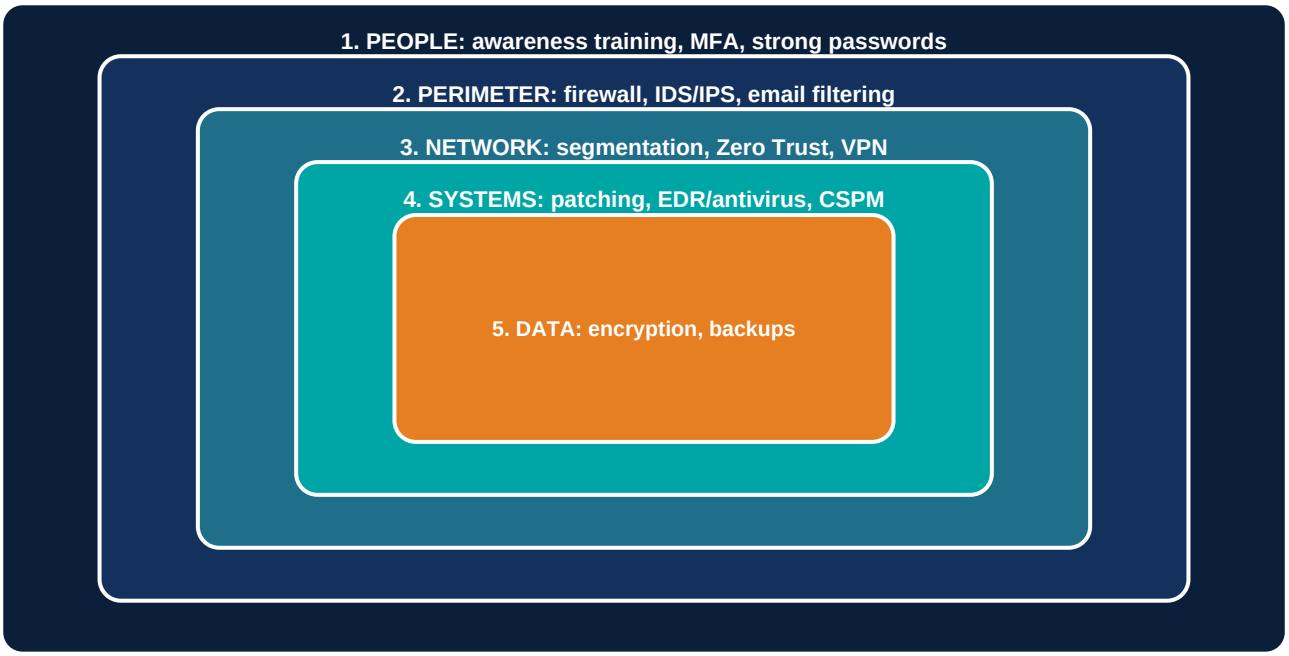


Figure 2: Defence in depth. Each layer protects the one inside it, with data at the centre.

4. Conclusion & Future Scope

The five threats in this report are different, but they share a pattern: attackers use **weak people habits, weak settings and unpatched software**. Most of the case studies could have been reduced or stopped by basic steps such as MFA, patching, correct configuration, backups and staff training. Acting **before** an attack is far cheaper than recovering after one.

Threats keep changing, especially as AI makes attacks faster and more convincing. Future areas to watch include deepfake-based fraud, AI-assisted malware, supply-chain attacks, cloud and API security, and the security of billions of connected devices. Because of this, cybersecurity is not a one-time task. Individuals, students and professionals must **keep learning**, follow trusted sources like CISA, KrebsOnSecurity and IBM Security, and practise safe habits every day.

> **Final takeaway**
> Be proactive, stay updated, and treat security as everyone's responsibility.

5. References

[1] CISA. Cybersecurity Alerts & Advisories. https://www.cisa.gov/news-events/cybersecurity-advisories

[2] CISA. #StopRansomware: DarkSide Ransomware (AA21-131A). https://www.cisa.gov/news-events/cybersecurity-advisories/aa21-131a

[3] CISA. #StopRansomware: CL0P Ransomware Gang Exploits MOVEit (AA23-158A). https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-158a

[4] KrebsOnSecurity. KrebsOnSecurity Hit With Record DDoS (2016). https://krebsonsecurity.com/2016/09/krebsonsecurity-hit-with-record-ddos/

[5] KrebsOnSecurity. What We Know So Far About the Capital One Breach. https://krebsonsecurity.com

[6] IBM Security. Cost of a Data Breach Report 2024. https://www.ibm.com/reports/data-breach

[7] IBM Security Blog. https://www.ibm.com/blog/category/security/

[8] Verizon. Data Breach Investigations Report (DBIR). https://www.verizon.com/business/resources/reports/dbir/

[9] ENISA. Threat Landscape. https://www.enisa.europa.eu/topics/cyber-threats/threats-and-trends

[10] OWASP. OWASP Top 10 Web Application Security Risks. https://owasp.org/www-project-top-ten/

[11] CNN. Finance worker pays out $25 million after video call with deepfake CFO (Arup case, 2024). https://edition.cnn.com/2024/05/16/tech/arup-deepfake-scam-loss-hong-kong-intl-hnk

[12] Capital One. 2019 Cyber Incident information. https://www.capitalone.com/digital/facts2019/

[13] NIST. Zero Trust Architecture (SP 800-207). https://csrc.nist.gov/pubs/sp/800/207/final